

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic, modern aesthetic.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

SEC324

Operate a data perimeter within a multi-account AWS environment

Remek Hetman

Principal Solutions Architect
AWS

Ilya Epshteyn

Sr. Manager, Identity Solutions
AWS



Agenda

Introduction to data perimeters

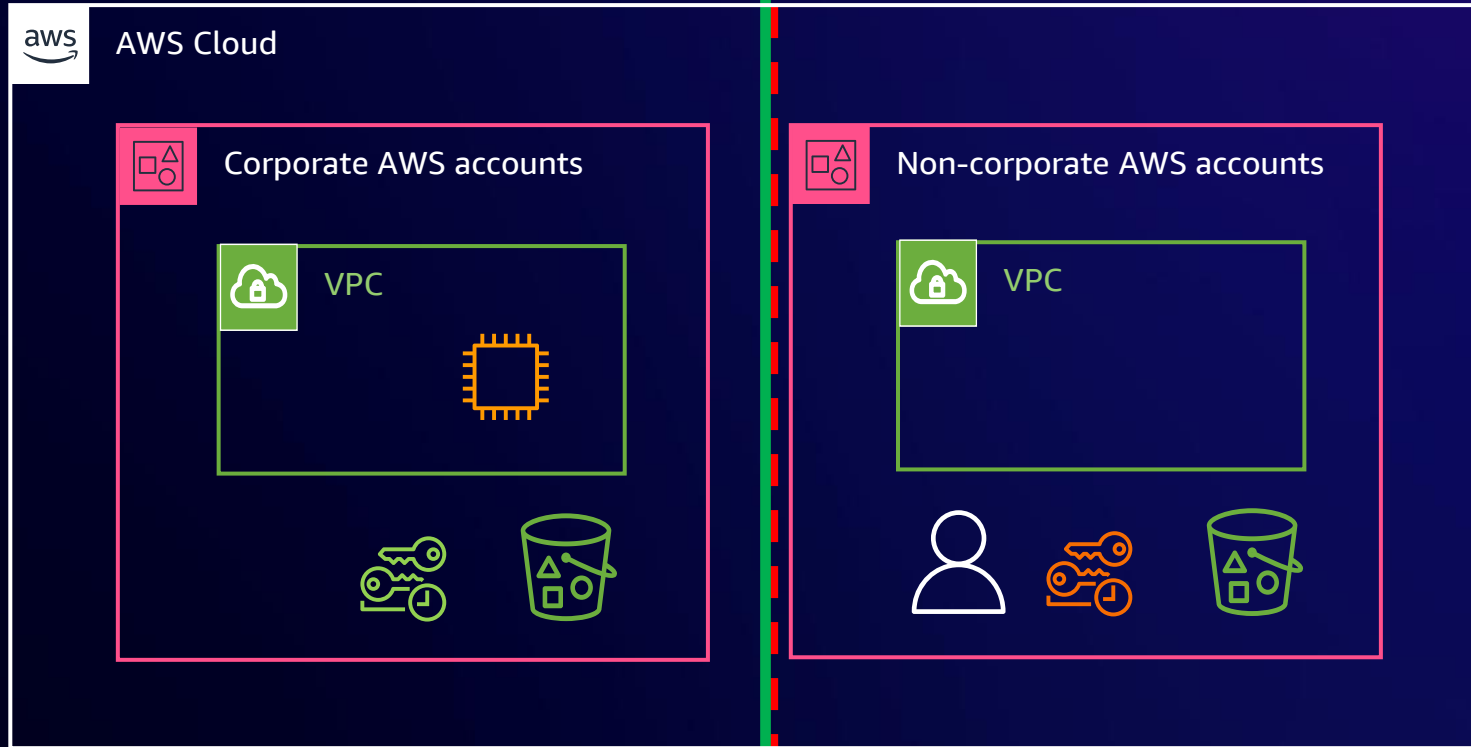
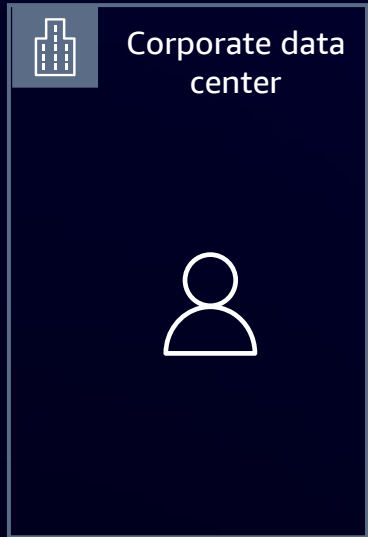
Customer-like environment (Mirror World)

Data perimeter controls

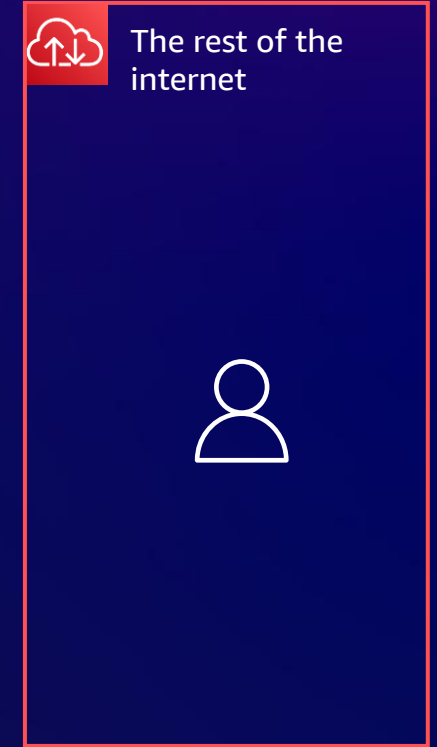
Data perimeter implementation at scale

What are data perimeters?

THINGS THAT BELONG TO ME

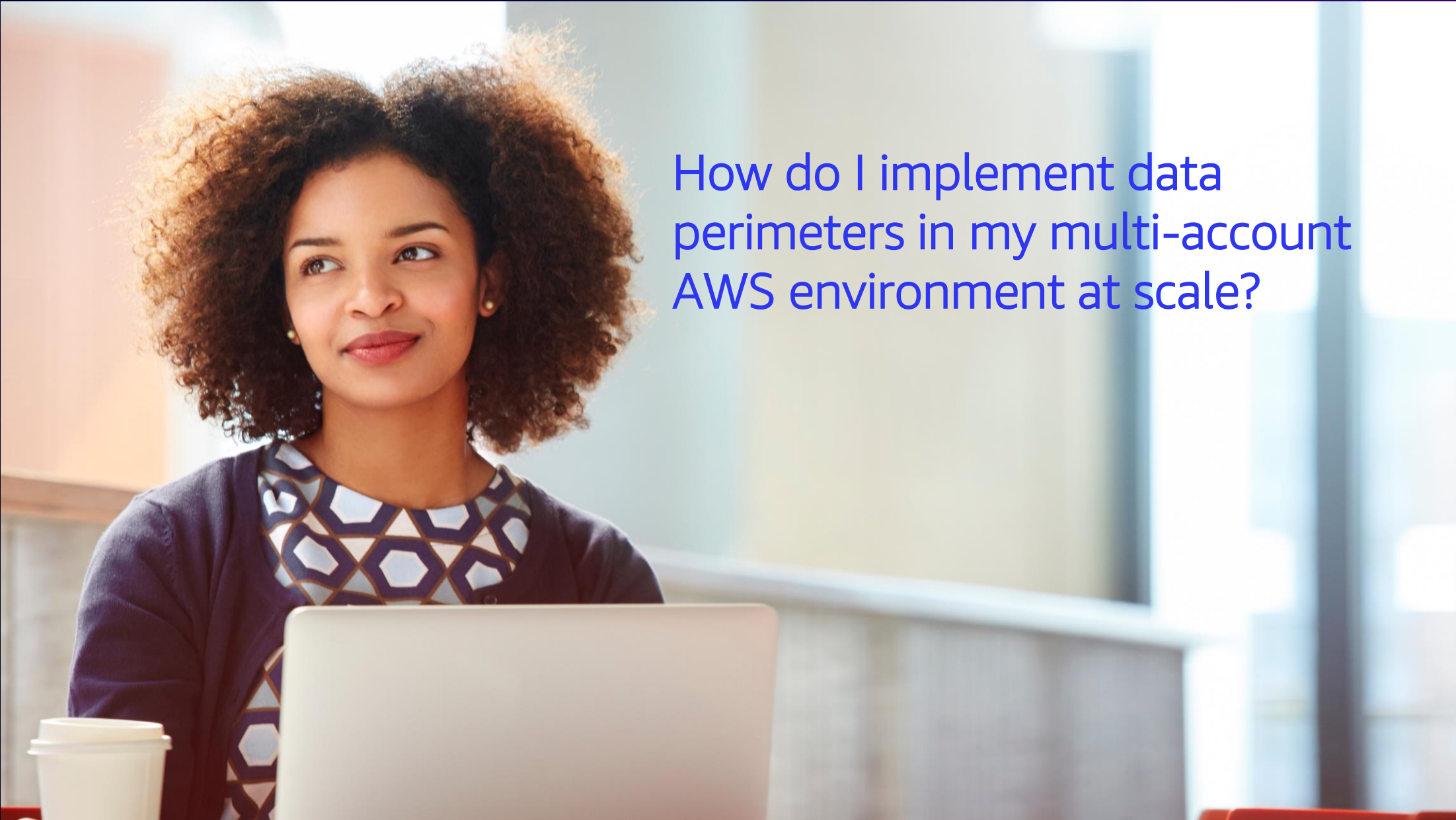


THINGS THAT DO NOT BELONG TO ME



Data perimeter controls

Perimeter	Intent/Control objective	Applied on	Using	Primary IAM capability
Identity	Only trusted identities can access my resources	Resources	Resource-based policy	aws:PrincipalOrgID aws:PrincipalIsAWSService
	Only trusted identities are allowed from my network	Network	VPC endpoint policy	aws:PrincipalOrgID aws:PrincipalIsAWSService
Resource	My identities can access only trusted resources	Identities	Service control policy	aws:ResourceOrgID
	Only trusted resources can be accessed from my network	Network	VPC endpoint policy	aws:ResourceOrgID
Network	My identities can access resources only from expected networks	Identities	Service control policy	aws:SourceIp aws:SourceVpc/aws:SourceVpce aws:ViaAWSService
	My resources can only be accessed from expected networks	Resources	Resource-based policy	aws:SourceIp aws:SourceVpc/aws:SourceVpce aws:ViaAWSService aws:PrincipalIsAWSService

A woman with voluminous curly hair is looking at a laptop screen. She is wearing a dark blue cardigan over a patterned top. A white coffee cup is visible on the table next to the laptop. The background is a bright, out-of-focus office or cafe setting.

How do I implement data
perimeters in my multi-account
AWS environment at scale?

Identity Solutions team

- **Active empathy (primary team tenet)**

We're serious about putting ourselves in customers' shoes. We want to experience customer pain points firsthand to understand them deeply and help remediate them.

- To be in "customers' shoes" we built and operate a large-scale AWS environment called Mirror World

Mirror World

- Multi-account AWS organization with account vending using AWS Control Tower
- Each account is deployed with baseline networking and security controls using a fully automated Customizations for AWS Control Tower (CfCT) pipeline
- Reference implementation for data perimeter and other enterprise controls
- Account vending to AWS internal service and field teams

Preventive controls in Mirror World

Enterprise control objectives

- Protect sensitive resources
 - Centrally owned resources
 - Security services
 - Privileged role modification and role assumption
- Prevent public access
- Limit actions to approved Regions
- Deny root in child accounts
- Enforce encryption in transit

Data perimeter control objectives

- Only trusted identities can access my resources
- Only trusted identities are allowed from my network
- My identities can access only trusted resources
- Only trusted resources can be accessed from my network
- My identities can access resources only from expected networks
- My resources can only be accessed from expected networks

Detective data perimeter controls in Mirror World

- Identity perimeter
 - IAM Access Analyzer cross-account access findings (organization or account zone of trust)
- Network perimeter
 - Amazon GuardDuty findings
 - UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.InsideAWS
 - UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.OutsideAWS
 - UnauthorizedAccess:IAMUser/MaliciousIPCaller
 - UnauthorizedAccess:IAMUser/MaliciousIPCaller.Custom
- Resource configurations (AWS Config/AWS Security Hub)
 - Block public access not enabled
 - Resources deployed outside of VPC

Data perimeter implementation at scale

Perimeter	Control objective	Implemented using	Primary IAM capability	Automation/enforcement
Identity	Only trusted identities can access my resources	Resource-based policies	PrincipalOrgID PrincipalIsAWSService	Config rules + AWS Lambda
	Only trusted identities are allowed from my network	VPC endpoint policies	PrincipalOrgID PrincipalIsAWSService	VPC endpoint AWS CloudFormation template
Resource	My identities can access only trusted resources	Service control policies	ResourceOrgID	Data perimeter SCP (applied at Root/OU level)
	Only trusted resources can be accessed from my network	VPC endpoint policies	ResourceOrgID	VPC endpoint AWS CloudFormation template
Network	My identities can access resources only from expected networks	Service control policies	SourceIp SourceVpc ViaAWSService	Data perimeter SCP (applied at Account level)
	My resources can only be accessed from expected networks	Resource-based policies	SourceIp SourceVpc ViaAWSService PrincipalIsAWSService	Config rules + AWS Lambda

Implementation: Identity and network perimeter on resources

Identity and network perimeter on resources

Perimeter	Control objective	Implemented using	Primary IAM capability	Automation/enforcement
Identity	Only trusted identities can access my resources	Resource-based policies	PrincipalOrgID PrincipalIsAWSService	Config rules + AWS Lambda
Network	My resources can only be accessed from expected networks	Resource-based policies	SourceIp SourceVpc ViaAWSService PrincipalIsAWSService	Config rules + AWS Lambda

Identity and network perimeter on resources

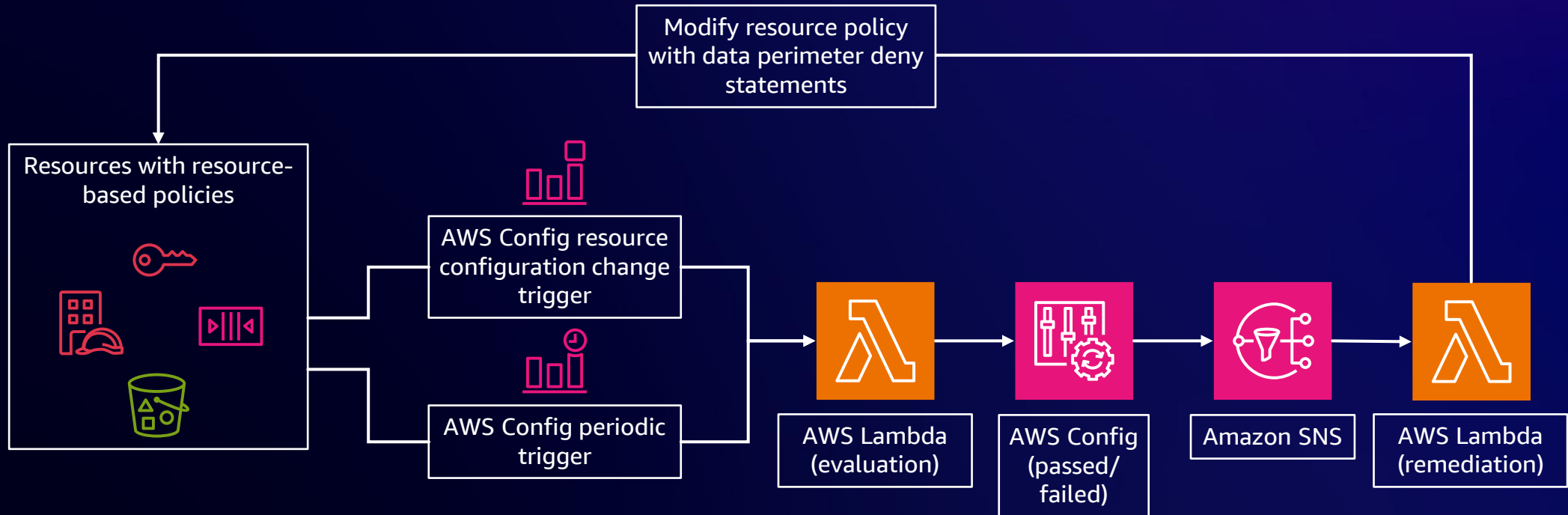
```
{
  "Sid": "EnforceIdentityPerimeter",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": [
    "{{resource_arn}}",
    "{{resource_arn}}/*"
  ],
  "Condition": {
    "StringNotEqualsIfExists": {
      "aws:PrincipalOrgID": "<my-org-id>",
      "aws:PrincipalAccount": [
        "{{allowed_external_accounts}}"
      ]
    },
    "BoolIfExists": {
      "aws:PrincipalIsAWSService": "false"
    }
  }
}
```

```
{
  "Sid": "EnforceNetworkPerimeter",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": [
    "{{resource_arn}}",
    "{{resource_arn}}/*"
  ],
  "Condition": {
    "NotIpAddressIfExists": {
      "aws:SourceIp": "{{org_cidr}}"
    },
    "StringNotEqualsIfExists": {
      "aws:SourceVpc": "{{source_vpcs}}",
      "aws:PrincipalTag/network-perimeter-exception": "true",
      "aws:PrincipalAccount": [
        "{{allowed_external_accounts}}"
      ]
    }
  },
  ...
}
```



Identity and network perimeter on resources

AWS Config rules trigger a Lambda function to modify resource-based policies



Identity and network perimeter on resources

Amazon S3 bucket policy example

```
{
  "Sid": "EnforceIdentityPerimeter",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": [
    "{{resource_arn}}",
    "{{resource_arn}}/*"
  ],
  "Condition": {
    "StringNotEqualsIfExists": {
      "aws:PrincipalOrgID": "<my-org-id>",
      "aws:PrincipalAccount": [
        "{{allowed_external_accounts}}"
      ]
    },
    "BoolIfExists": {
      "aws:PrincipalIsAWSService": "false"
    }
  }
}
```

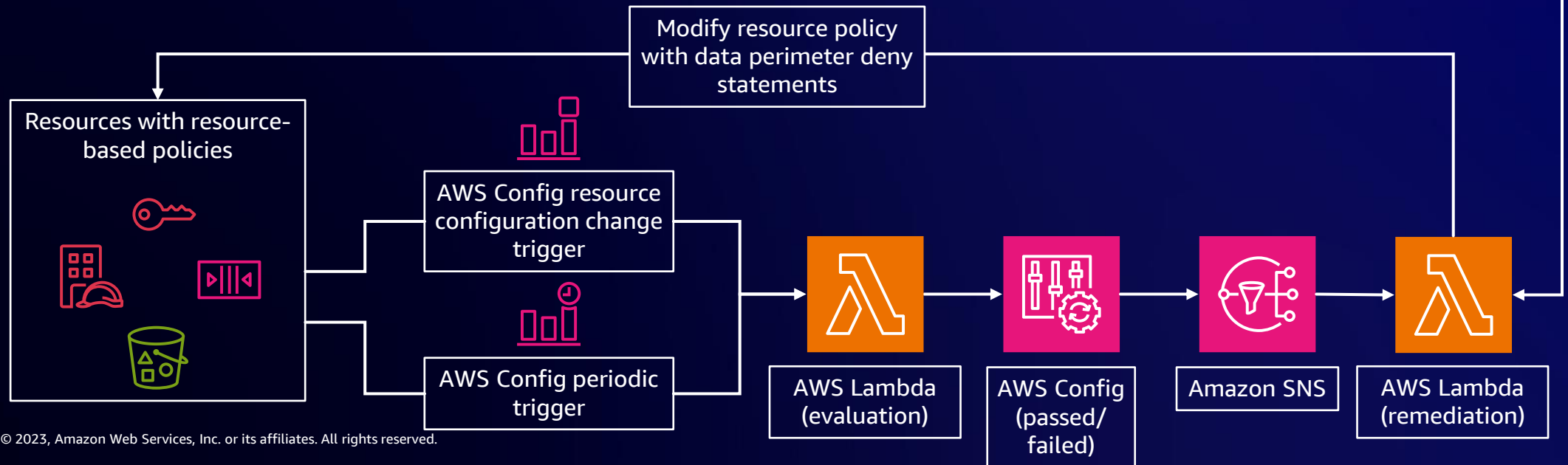
```
{
  "Sid": "EnforceNetworkPerimeter",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": [
    "{{resource_arn}}",
    "{{resource_arn}}/*"
  ],
  "Condition": {
    "NotIpAddressIfExists": {
      "aws:SourceIp": "{{org_cidr}}"
    },
    "StringNotEqualsIfExists": {
      "aws:SourceVpc": "{{source_vpcs}}",
      "aws:PrincipalTag/network-perimeter-exception": "true",
      "aws:PrincipalAccount": [
        "{{allowed_external_accounts}}"
      ]
    }
  },
  ...
}
```

Automation to
populate customer
network definitions



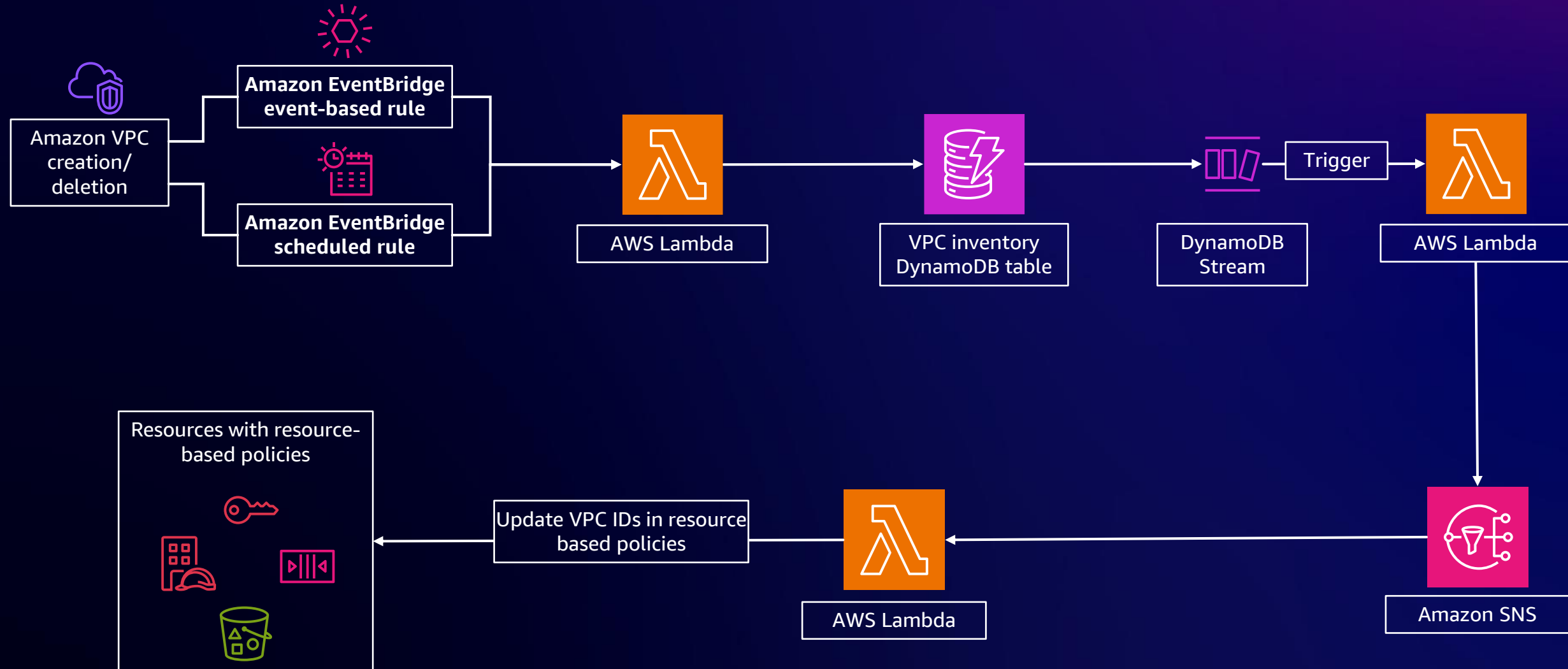
Identity and network perimeter on resources

New resource creation flow



Identity and network perimeter on resources

New VPC creation/deletion flow



Implementation: Identity and resource perimeter on network

Identity and resource perimeter on network

Perimeter	Control objective	Implemented using	Primary IAM capability	Automation/enforcement
Identity	Only trusted identities are allowed from my network	VPC endpoint policies	PrincipalOrgID PrincipalIsAWSService	VPC endpoint AWS CloudFormation template
Resource	Only trusted resources can be accessed from my network	VPC endpoint policies	ResourceOrgID	VPC endpoint AWS CloudFormation template

Identity and resource perimeter on network

```
{
  "Sid": "AccessToTrustedPrincipalsAndResources",
  "Effect": "Allow",
  "Principal": {
    "AWS": "*"
  },
  "Action": "s3:*",
  "Resource": "*",
  "Condition": {
    "StringEquals": {
      "aws:ResourceOrgID": "{{org_id}}",
      "aws:PrincipalOrgID": "{{org_id}}"
    }
  }
}
```

```
{
  "Sid":
  "AllowUnauthenticatedRequestsToAWSResources",
  "Effect": "Allow",
  "Principal": "*",
  "Action": [
    "s3:GetObject"
  ],
  "Resource": [
    "arn:aws:s3:::packages.<REGION>.amazonaws.com/*",
    "arn:aws:s3:::repo.<REGION>.amazonaws.com/*",
    "arn:aws:s3:::amazonlinux.<REGION>.amazonaws.com/*",
    "arn:aws:s3:::amazonlinux-2-repos-<REGION>/*"
  ]
}
...

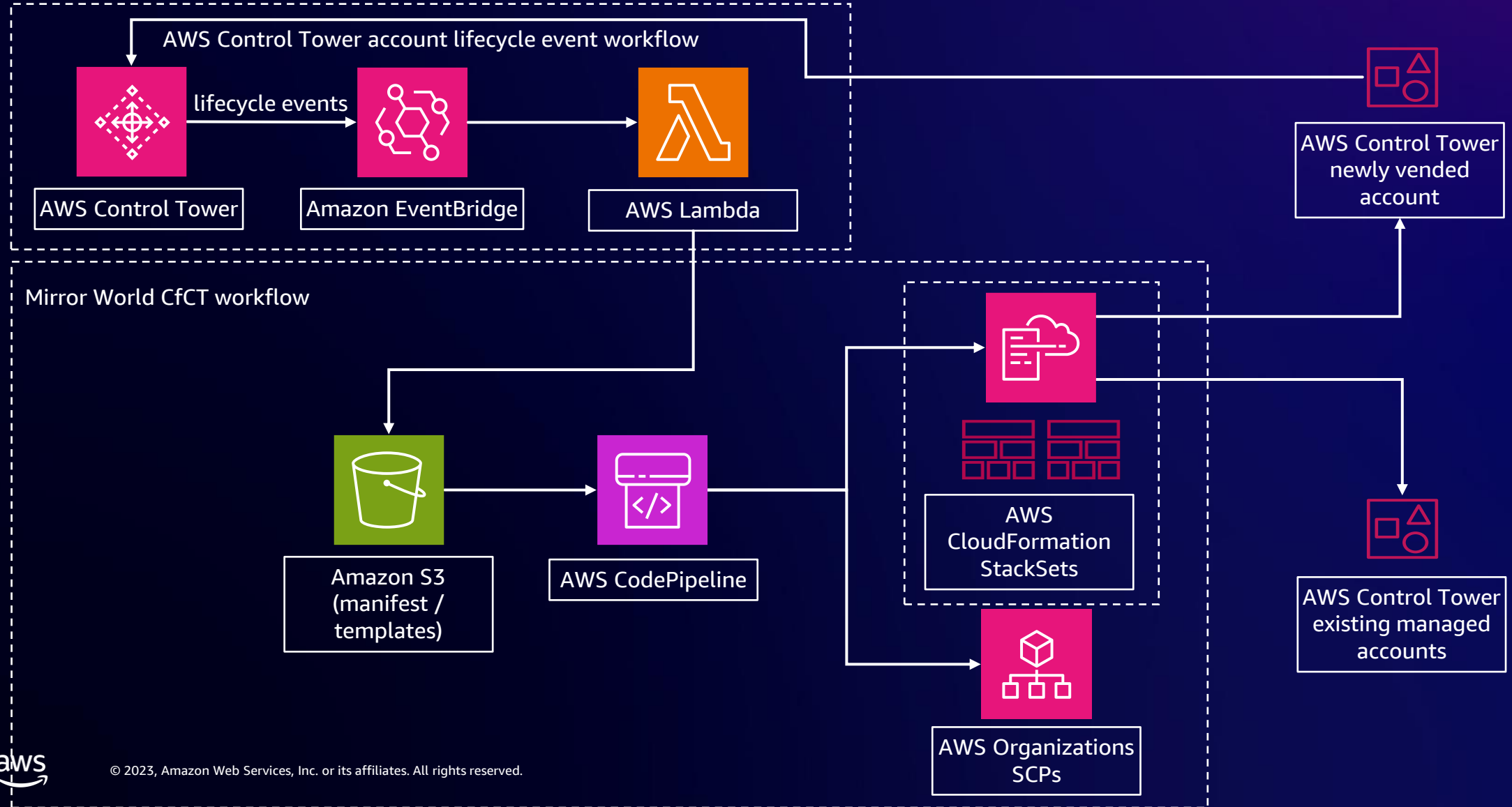
```

Exceptions for anonymous requests made to AWS-owned resources (buckets for patching)



Identity and resource perimeter on network

VPC endpoints with data perimeter policies are created when new accounts are vended



Implementation: Resource and network perimeter on identity

Resource and network perimeter on identity

Perimeter	Control objective	Implemented using	Primary IAM capability	Automation/enforcement
Resource	My identities can access only trusted resources	Service control policies	ResourceOrgID	Data perimeter SCP (applied at OU level)
Network	My identities can access resources only from expected networks	Service control policies	Sourcelp SourceVpc ViaAWSService	Data perimeter SCP (applied at account level)



Resource and network perimeter on identity

Root/OU level

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "EnforceResourcePerimeterAWSResources",
      "Effect": "Deny",
      "NotAction": [
        "<action>"
      ],
      "Resource": "*",
      "Condition": {
        "StringNotEqualsIfExists": {
          "aws:ResourceOrgID": "<my-org-id>"
        }
      }
    },
    {
      "Sid": "EnforceResourcePerimeterThirdPartyResources",
      "Effect": "Deny",
      "Action": "<action>",
      "Resource": "*",
      "Condition": {
        "StringNotEqualsIfExists": {
          "aws:ResourceOrgID": "<my-org-id>",
          "aws:ResourceAccount": [
            "<third-party-account-a>",
            "<third-party-account-b>"
          ]
        }
      }
    }
  ]
}
```

Exclude actions for trusted third party access which are then restricted in the statement on the right



Resource and network perimeter on identity

Account level

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "EnforceNetworkPerimeter",
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "BoolIfExists": {
          "aws:ViaAWSService": "false"
        },
        "NotIpAddressIfExists": {
          "aws:SourceIp": [
            "{{org_cidr}}"
          ]
        },
        "StringNotEqualsIfExists": {
          "aws:SourceVpc": [
            "{{source_vpcs}}"
          ]
        },
        "ArnNotLikeIfExists": {
          "aws:PrincipalArn": [
            "arn:aws:iam::*:role/aws:ec2-
            infrastructure"
          ]
        },
        "StringEquals": {
          "aws:PrincipalTag/data-perimeter-include":
            "true"
        }
      }
    }
  ]
}
```

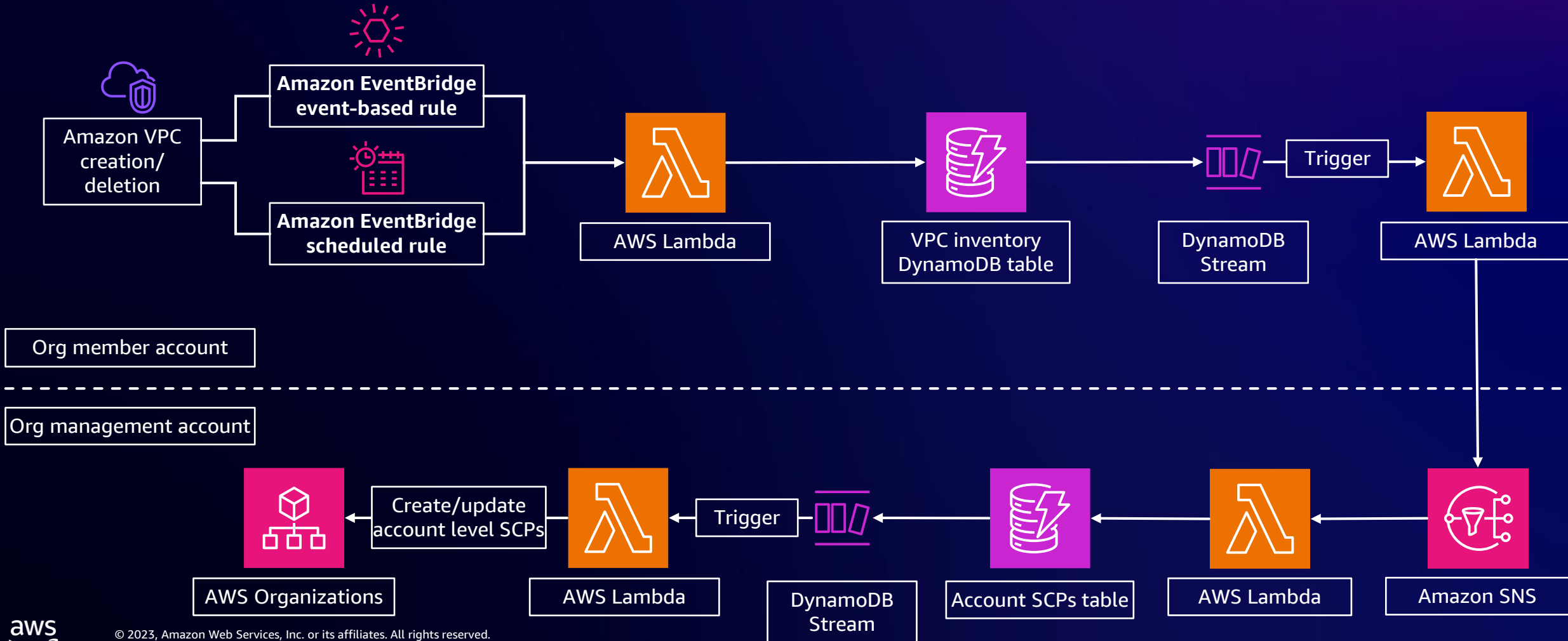
Automation to populate customer network definitions

...



Identity and network perimeter on resources

Network perimeter applied using an account-level SCP



Resource and network perimeter on identity

Additional automation

- Merge statements with the same effect, resource, condition, and action
- Compact the policy by removing whitespace and “bin packing” the policy
- 50%+ space reduction in Mirror World environment!

Resources

- Service control policy repository
<https://github.com/aws-samples/service-control-policy-examples>
- Data perimeters on AWS
<https://aws.amazon.com/identity/data-perimeters-on-aws/>
- Establishing a Data Perimeter on AWS Blog Series
<https://aws.amazon.com/identity/data-perimeters-blog-post-series/>

Thank you!

Remek Hetman

rhetman@amazon.com

Ilya Epshteyn

ilyep@amazon.com



Please complete the session survey in the mobile app

